

Lista de verificação de controles e conformidade

Para preencher a lista de verificação de avaliação de controles, consulte as informações fornecidas no [relatório de escopo, metas e avaliação de riscos](#). Para mais detalhes sobre cada controle, incluindo o tipo e a finalidade, consulte o [documento de categorias de controle](#).

Em seguida, selecione "sim" ou "não" para responder à pergunta: A Botium Toys possui atualmente este controle implementado?

Lista de verificação de avaliação de controles

Sim	Não	Controle
☐	☒	Princípio do menor privilégio
☐	☒	Planos de recuperação de desastres
☒	☐	Políticas de senha
☐	☒	Separação de funções
☒	☐	Firewall
☐	☒	Sistema de detecção de intrusão (IDS)
☐	☒	Backups
☒	☐	Software antivírus
☒	☐	Monitoramento manual, manutenção e intervenção em sistemas legados
☐	☒	Criptografia
☐	☒	Sistema de gerenciamento de senhas
☒	☐	Fechaduras (escritórios, loja, depósito)
☒	☐	Monitoramento por circuito fechado de televisão (CCTV)

- ☒ ☐ Detecção/prevenção de incêndio (alarme de incêndio, sistema de sprinklers etc.)
-

Para preencher a lista de verificação de conformidade, consulte as informações fornecidas no [relatório de escopo, metas e avaliação de riscos](#). Para mais detalhes sobre cada requisito de conformidade, revise o conteúdo sobre [controles, frameworks e conformidade](#).

Em seguida, selecione "sim" ou "não" para responder à pergunta: A Botium Toys segue atualmente esta boa prática de conformidade?

Lista de verificação de conformidade

Padrão de Segurança de Dados da Indústria de Cartões de Pagamento (PCI DSS)

Sim	Não	Boa prática
☐	☒	Somente usuários autorizados têm acesso às informações de cartão de crédito dos clientes.
☐	☒	As informações de cartão de crédito são armazenadas, aceitas, processadas e transmitidas internamente em um ambiente seguro.
☐	☒	Implementar procedimentos de criptografia de dados para proteger melhor os pontos de contato das transações com cartão de crédito e os dados.
☐	☒	Adotar políticas seguras de gerenciamento de senhas.

Regulamento Geral sobre a Proteção de Dados (GDPR)

Sim	Não	Boa prática
☐	☒	Os dados dos clientes da União Europeia são mantidos privados/seguros.
☒	☐	Existe um plano para notificar os clientes da União Europeia em até 72 horas se seus dados forem comprometidos ou houver uma violação.
☐	☒	Garantir que os dados sejam devidamente classificados e inventariados.

- | | | |
|-------------------------------------|--------------------------|--|
| ☒ | ☐ | Aplicar políticas, procedimentos e processos de privacidade para documentar e manter os dados adequadamente. |
|-------------------------------------|--------------------------|--|

Controles de Sistemas e Organizações (SOC tipo 1, SOC tipo 2)

Sim	Não	Boa prática
☐	☒	As políticas de acesso dos usuários estão estabelecidas.
☐	☒	Os dados sensíveis (PII/SPII) são confidenciais/privados.
☒	☐	A integridade dos dados garante que eles sejam consistentes, completos, precisos e tenham sido validados.
☒	☐	Os dados estão disponíveis para as pessoas autorizadas a acessá-los.

Recomendações (opcional): A Botium Toys deve melhorar os controles de acesso, fortalecer as políticas de senha, implementar criptografia e backups e adicionar um sistema de detecção de intrusão. Essas medidas ajudariam a proteger dados sensíveis, reduzir riscos de segurança e melhorar a conformidade com os requisitos do PCI DSS, GDPR e SOC.